٢

حوكمة أمن المعلومات

من الحماية التقنية إلى القيادة والمساءلة المؤسسية

ما هي الحوكمة؟

1

تعريف عام

مجموعة الأنظمة والعمليات التي توجّه وتراقب أداء المؤسسة لتحقيق أهدافها

2

الفكرة الجوهرية

الحوكمة تجيب عن سؤال :من يقرر؟ وكيف تتم المساءلة؟

3

التطبيق في الأمن السيبراني

امتداد لمفهوم الحوكمة المؤسسية العامة ليشمل حماية المعلومات والأنظمة

ما المقصود بحوكمة أمن المعلومات؟

1

التعريف

الإطار الذي يحدد من خلاله مجلس الإدارة والإدارة التنفيذية التوجهات والأهداف والمسؤوليات المتعلقة بأمن المعلومات

2

الربط الاستراتيجي

مواءمة استراتيجية الأمن السيبراني مع أهداف العمل العامة للمؤسسة

3

بُعد المساءلة

تحديد من يملك القرار، ومن يُساءل عند وقوع حادث أمني

لماذا تحتاج المؤسسات إلى حوكمة أمنية؟

1

مواءمة الأهداف

ربط جهود الأمن السيبراني بأهداف العمل والاستراتيجية العامة

2

إدارة المخاطر

توفير رؤية شاملة للمخاطر واتخاذ قرارات مبنية على أولويات واضحة

3

الامتثال التنظيمي

الالتزام بالأنظمة والتشريعات المحلية والدولية ذات الصلة

4

بناء الثقة

طمأنة العملاء والشركاء والمستثمرين حول جدية حماية بياناتهم

الحوكمة مقابل الإدارة

الحوكمة (Governance)

- وضع التوجهات والأهداف الاستراتيجية
- اعتماد السياسات والإشراف عليها
- تحديد المسؤوليات والمساءلة
- متابعة الأداء العام على مستوى المجلس

الإدارة (Management)

- التنفيذ اليومي للأنشطة والمهام
- تطبيق السياسات والإجراءات المعتمدة
- الاستجابة التشغيلية للحوادث
- تقارير الأداء التشغيلي

الأركان الأساسية لحوكمة أمن المعلومات

1

القيادة والالتزام

دعم واضح من الإدارة العليا ومجلس الإدارة

2

الهيكل التنظيمي

تحديد الأدوار والمسؤوليات بوضوح داخل المؤسسة

3

السياسات والمعايير

وثائق ناظمة توجّه السلوك والقرارات الأمنية

4

إدارة المخاطر

تحديد المخاطر وتقييمها ومعالجتها بشكل منهجي

5

الامتثال

الالتزام بالمتطلبات القانونية والتنظيمية ذات الصلة

6

قياس الأداء

مؤشرات ومراجعات دورية لتقييم فعالية الحوكمة

من يشارك في حوكمة أمن المعلومات؟

1. **مجلس الإدارة**
   يضع التوجهات العليا ويراقب الالتزام بها على مستوى المؤسسة

2. **الإدارة التنفيذية**
   تترجم توجهات المجلس إلى استراتيجيات وخطط قابلة للتنفيذ

3. **مسؤول أمن المعلومات (CISO)**
   يقود البرنامج الأمني ويرفع التقارير للإدارة العليا

4. **الموظفون والمستخدمون**
   يلتزمون بالسياسات ويشكلون خط الدفاع الأول في الممارسة اليومية

المشهد التشريعي والتنظيمي)لمحة عامة(

1

أنظمة حماية البيانات الدولية

مثل اللائحة الأوروبية العامة لحماية البيانات GDPR

2

الأنظمة والتشريعات المحلية

قوانين حماية البيانات وأمن المعلومات الخاصة بكل دولة

3

متطلبات القطاعات الحساسة

قطاعات كالمال والصحة تخضع لمتطلبات تنظيمية إضافية

4

أهمية الامتثال

يشكل الامتثال جزءاً أساسياً من حوكمة أمن المعلومات وليس مجرد التزام قانوني

أطر الحوكمة التي سندرسها لاحقاً

1

NIST CSF 2.0

إطار أمريكي شامل يضم وظيفة مخصصة للحوكمة (Govern)

2

ISO/IEC 27014

معيار دولي متخصص في حوكمة أمن المعلومات

3

ISO/IEC 27001

معيار عالمي لأنظمة إدارة أمن المعلومات وشهادة الاعتماد

4

COBIT 2019

إطار متكامل لحوكمة تقنية المعلومات على مستوى المؤسسة

مفهوم المخاطر السيبرانية

1

الخطر Risk

احتمال وقوع حدث يؤثر سلباً على أصول المؤسسة أو أهدافها

2

التهديد Threat

أي مصدر محتمل يمكن أن يستغل ثغرة لإحداث ضرر

3

الثغرة Vulnerability

نقطة ضعف في النظام يمكن استغلالها من قبل التهديد

4

لماذا يهم في الحوكمة؟

إدارة المخاطر تُترجم القرارات الاستراتيجية إلى إجراءات عملية ـــ سنتوسع فيها لاحقاً

فرص العمل في حوكمة الأمن السيبراني

1

مسؤول أمن المعلومات CISO

القيادة الاستراتيجية لبرنامج الأمن السيبراني

2

محلل امتثال ومخاطر

تقييم الالتزام بالسياسات والمعايير التنظيمية

3

مدقق أمن المعلومات

مراجعة الضوابط الأمنية والتحقق من فعاليتها

4

مستشار حوكمة تقنية المعلومات

دعم المؤسسات في بناء أطر حوكمة فعالة

أهم المصطلحات في هذه المحاضرة

Cybersecurity	الأمن السيبراني :حماية الأنظمة والشبكات والبيانات من التهديدات الرقمية
CIA Triad	مثلث السرية والسلامة والتوافر، ركيزة أمن المعلومات الأساسية
Governance	الحوكمة :أنظمة توجيه ومراقبة أداء المؤسسة لتحقيق أهدافها
CISO	مسؤول أمن المعلومات الأول، المسؤول التنفيذي عن البرنامج الأمني
Compliance	الامتثال :الالتزام بالمتطلبات القانونية والتنظيمية والمعيارية
Risk	الخطر :احتمال تأثر أصول المؤسسة سلباً نتيجة تهديد يستغل ثغرة

نشاط تفاعلي

سؤال للنقاش

برأيك، لماذا لا تكفي الحلول التقنية وحدها لحماية المؤسسات من التهديدات السيبرانية؟

- فكّر في دور السياسات والوعي البشري
- فكّر في دور القيادة العليا في اتخاذ القرار
- شارك مثالاً واقعياً إن أمكن

أهم ما ينبغي تذكّره من هذه المحاضرة

1. الأمن السيبراني يقوم على حماية السرية والسلامة والتوافر لأصول المعلومات
2. التهديدات متنوعة ومتطورة، وتشمل عوامل تقنية وبشرية معاً
3. حوكمة أمن المعلومات توجّه القرارات الأمنية وتربطها بأهداف المؤسسة
4. الحوكمة تختلف عن الإدارة :الأولى توجّه وتراقب، والثانية تنفّذ وتشغّل
5. الأركان الستة للحوكمة تشكل الأساس الذي سنبني عليه بقية المقرر

نظرة على الأسبوع الثاني

1

الموضوع القادم

الفرق بين الحوكمة والإدارة في الأمن السيبراني

2

سيتم التوسع في

أدوار كل من مجلس الإدارة، الإدارة التنفيذية، والفرق التشغيلية

3

تحضير مطلوب

مراجعة مفاهيم هذه المحاضرة، خاصة أركان الحوكمة وأصحاب المصلحة

المراجع والمصادر

مصادر مقترحة لتعميق الفهم حول مواضيع هذه المحاضرة

— NIST Cybersecurity Framework (CSF) 2.0 — National Institute of Standards and Technology

— ISO/IEC 27001 & ISO/IEC 27014 — المنظمة الدولية للمعايير—

— COBIT 2019 Framework — ISACA

—شكراً لحسن استماعكم —الأسئلة مرحّب بها